Mise en production, RGPD et sécurité

The Bill Please — plateforme d'extraction automatique de factures

Note de synthèse · 21 septembre 2026

La plateforme lit des factures (PDF ou photos, imprimées ou manuscrites, français ou anglais), en extrait le fournisseur, le numéro, la date, le montant et la TVA, et les présente dans un tableau vérifiable, corrigeable et exportable en Excel. Chaque client entreprise dispose de son propre sous-domaine, de sa propre base et de son propre espace de fichiers. Ce document répond à quatre questions : quel serveur choisir, que valider avant l'ouverture du service, ce qu'implique le RGPD quand les factures transitent par l'IA, et l'état de la sécurité du code.

1. Quel serveur pour la production

Une seule machine virtuelle Linux chez un hébergeur européen — OVHcloud ou Scaleway (France), ou Hetzner (Allemagne). Dimensionnement de départ : **4 cœurs, 8 Go de mémoire, 160 Go de disque**, soit environ **25 € par mois**, plus ~5 €/mois de sauvegardes.

> **Pourquoi une seule machine, et pas un hébergement « élastique » (Cloud Run, Lambda) :** l'application garde son état dans le processus lui-même — les bases de données, l'avancement de l'import en cours, le verrou qui empêche deux imports simultanés, le compteur de tentatives de connexion. Deux exemplaires en parallèle se marcheraient dessus. Ce choix est adapté à quelques dizaines de clients ; au-delà, il faut changer de socle (voir §2).

ÉLÉMENT	CHOIX RECOMMANDÉ	RAISON
Hébergeur	OVHcloud / Scaleway / Hetzner, région UE	Données clients hébergées dans l'Union européenne : argument contractuel et simplification RGPD
Machine	4 cœurs / 8 Go / 160 Go SSD	8 factures traitées en parallèle ; la conversion des PDF en images consomme le processeur, les envois en cours occupent la mémoire
Disque	160 Go, extensible	~2 Go par client et par an de factures originales
HTTPS	Caddy en frontal (certificats automatiques)	Chiffrement de bout en bout, renouvellement sans intervention
Application	Service système, un seul processus, en-têtes de proxy activés	L'état vit dans le processus ; les adresses IP des visiteurs doivent rester exactes
Sauvegardes	Quotidiennes, chiffrées, hors machine	Un instantané sur la même machine ne protège de rien

> **À anticiper avant de choisir le nom de domaine :** chaque client ayant son propre sous-domaine, il faut un certificat « joker » (`*.factures.example.com`). Il s'obtient uniquement via l'API du fournisseur DNS — tous ne la proposent pas.

2. Étapes et arbitrages avant l'ouverture

À faire, dans l'ordre

1. **Passer à une version récente de Python (3.11 ou 3.12) sur le serveur.** La version utilisée en développement, Python 3.8, ne reçoit plus de correctifs de sécurité depuis fin 2024.
2. **Renseigner les paramètres de production** : domaine de la plateforme, clé de signature des sessions, emplacement des données sur le disque sauvegardé.
3. **Mettre en place les sauvegardes chiffrées hors machine — et tester une restauration réelle.** Sans test de restauration, ce ne sont pas des sauvegardes.
4. **Superviser** : sonde de disponibilité, alerte sur le disque plein, rotation des journaux.
5. **Contractualiser** : contrat de sous-traitance avec chaque client (voir §3).

Arbitrages à trancher

DÉCISION	ENJEU
Rétention zéro chez Anthropic	Argument commercial fort. À demander à Anthropic, en vérifiant que le modèle utilisé y est éligible (voir §3)
Seuil de changement de socle	Au-delà d'environ 30 clients, ou si la haute disponibilité devient nécessaire : base PostgreSQL, stockage objet, et sortie de l'état des imports hors mémoire
Durée de conservation	Les pièces comptables se conservent 10 ans en France : environ 20 Go par client à terme. À refléter dans le tarif et les quotas
Modèle de facturation	Le coût d'analyse est d'environ 10 à 12 € pour 1 000 factures. À répercuter au volume ou en forfait avec quota
Gestion des comptes	Aujourd'hui en ligne de commande uniquement : ni mot de passe oublié, ni double authentification, ni rôles. À ajouter avant des clients non techniques
Analyse antivirus	La plateforme héberge des fichiers venus de l'extérieur : un antivirus à l'import est attendu dans tout audit client

3. RGPD : les factures transitent par l'IA

C'est faisable légalement, à condition de le contractualiser. Les éléments ci-dessous ont été vérifiés dans la documentation publique d'Anthropic en septembre 2026 (sources en fin de document). Ils ne constituent pas un avis juridique : le montage doit être validé par un avocat ou un délégué à la protection des données.

Ce à quoi Anthropic s'engage

- Le client **reste propriétaire** de ce qu'il envoie et de ce qui est produit.
- Les données des clients professionnels **ne servent pas à entraîner les modèles**, sauf activation explicite.
- Les données envoyées à l'API sont **supprimées sous 30 jours** par défaut.
- Une option de **rétention zéro** existe, sur demande et après validation, pour les modèles éligibles.
- Un **contrat de sous-traitance assorti des clauses contractuelles types** est inclus dès l'acceptation des conditions commerciales.

> **Le point sensible :** le traitement peut être routé vers plusieurs pays, mais les données sont **stockées aux États-Unis**. C'est un transfert hors Union européenne. Il est encadré par les clauses contractuelles types, mais il doit être écrit dans le contrat et annoncé aux clients — c'est le premier point que vérifiera un service achats ou un DPO.

Ce qui reste à la charge de l'éditeur

- **Un contrat de sous-traitance avec chaque client** : le client est responsable de traitement, l'éditeur sous-traitant, l'hébergeur et Anthropic sous-traitants ultérieurs — nommés, avec leur localisation.
- **Considérer que le RGPD s'applique**, même en contexte professionnel : une facture porte des noms de contacts, des signatures, des mentions manuscrites, et parfois des entrepreneurs individuels.
- **Registre des traitements**, procédure de notification de violation sous 72 heures, et politique de conservation conciliant le droit à l'effacement avec l'obligation légale de conserver les pièces comptables.
- **Point favorable :** l'architecture isole chaque client dans son propre dossier. L'export et l'effacement complet d'un client sont des opérations simples et vérifiables.

4. Audit de sécurité du code

Revue complète du code applicatif, accompagnée d'une suite de tests automatisés couvrant le cloisonnement entre clients, les sessions, le service des fichiers et les imports. Les failles ci-dessous ont été **corrigées et vérifiées par ces tests**.

GRAVITÉ	FAILLE	CORRECTIF
CRITIQUE	**Injection de code via un nom de fournisseur.** Le nom lu sur une facture était réinséré tel quel dans la page. Un tiers envoyant une facture au nom piégé faisait exécuter son code dans le navigateur du client, donc pouvait voler sa session	Les valeurs issues des documents sont insérées comme texte, jamais comme code. Politique de sécurité du contenu interdisant tout script en ligne en seconde barrière
CRITIQUE	**Écriture hors du dossier d'un client.** Un nom de fichier forgé pouvait faire écrire son contenu dans l'espace d'un autre client : le cloisonnement tombait	Le nom de stockage est dérivé de l'identifiant interne de la facture, l'extension est validée, et l'emplacement final est vérifié avant écriture

GRAVITÉ	FAILLE	CORRECTIF
ÉLEVÉE	**Fichier piégé servi comme page web.** Un fichier HTML déposé en guise de facture était renvoyé au navigateur comme une page du site	Seuls les PDF et les images s'affichent dans le navigateur ; tout autre format est renvoyé en téléchargement de type neutre
ÉLEVÉE	**Cookie de session non restreint au HTTPS**, donc interceptable sur une connexion non chiffrée	Restriction activée automatiquement dès que le domaine de production est configuré
MOYENNE	**Aucune limite de tentatives de connexion :** mots de passe testables en masse	Blocage de 5 minutes après 5 échecs, par compte et par adresse
MOYENNE	**Import sans limite de taille :** un seul envoi pouvait saturer la mémoire et couper le service de tous les clients	Plafond configurable, 500 Mo par défaut
MOYENNE	**Session survivant à la suppression d'un compte** pendant 12 heures	L'existence du compte est revérifiée à chaque requête
MOYENNE	**En-têtes de sécurité absents**	Politique de sécurité du contenu stricte, anti-reniflage de type, interdiction d'affichage dans un cadre tiers, interdiction de mise en cache des pages contenant des factures
FAIBLE	Session non réinitialisée au moment de la connexion	La session est vidée avant d'être réécrite

Points vérifiés et déjà conformes

- ✓ **Cloisonnement entre deux clients.** Depuis un espace client, les tentatives de lecture, de téléchargement et de modification des factures d'un autre client sont toutes refusées. Un cookie valide chez l'un ne fonctionne pas chez l'autre, et un sous-domaine inconnu renvoie une erreur au lieu de créer un espace.
- ✓ **Requêtes de base de données paramétrées** : tentative d'injection SQL par la recherche sans effet.
- ✓ **Seuls six champs sont modifiables** ; toute autre modification est rejetée par le serveur.
- ✓ **Mots de passe** protégés par scrypt, comparaison à temps constant, et coût identique qu'un compte existe ou non.
- ✓ **Clé d'accès à l'IA jamais exposée** : elle reste sur le serveur, aucune page ni aucun script ne la reçoit. Les échanges passent en HTTPS par la bibliothèque officielle.
- ✓ **Aucune donnée client versionnée** : factures, bases et secrets sont exclus du dépôt de code.

Points ouverts, à arbitrer

- **Archives piégées :** une archive minuscule se décompressant en plusieurs gigaoctets n'est pas détectée. Exploitation limitée aux utilisateurs authentifiés, mais à traiter avant l'ouverture commerciale.
- **Export Excel :** jusqu'à 100 000 lignes chargées en mémoire d'un seul tenant.
- **Pas de journal d'audit consultable** (connexions, modifications) ; les journaux techniques contiennent des adresses e-mail.
- **Pas d'analyse antivirus** des fichiers déposés.
- **Pas de chiffrement applicatif au repos :** le chiffrement du disque du serveur doit être activé.

5. Sources

- Conditions commerciales Anthropic — anthropic.com/legal/commercial-terms

- Utilisation des données pour l'entraînement — privacy.claude.com/en/articles/7996868-is-my-data-used-for-model-training
- Durée de conservation des données — privacy.claude.com/en/articles/7996866-how-long-do-you-store-my-organization-s-data
- Rétention zéro : périmètre et éligibilité — docs.anthropic.com/en/docs/build-with-claude/zero-data-retention
- Approche RGPD et clauses contractuelles types — privacy.claude.com/en/articles/10023628-what-is-your-approach-to-gdpr-or-related-issues
- Localisation des serveurs et du stockage — privacy.claude.com/en/articles/7996890-where-are-your-servers-located-do-you-host-your-models-on-eu-servers

---

Document de travail — The Bill Please. Les éléments juridiques sont indicatifs et ne remplacent pas l'avis d'un avocat ou d'un délégué à la protection des données.